

# Security+ 3.4 · Recovery Testing

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.4 — Recovery Testing (5:18)** · [Vídeo no YouTube ↗](#)

---

**Resumo da Aula:** Teste o plano de recovery ANTES do desastre: restaura backup, simulada falha. RPO (quanto dato perde) e RTO (quanto tempo pra voltar). Table-top / parallel / full failover.

## Highlights que a prova cobra

---

- RPO: quantos dados podes perder; RTO: quando volta
- Plano NÃO-testado = plano que NÃO funcionará

## Dicas de prova & Cenários Típicos

---

- 'maximum data loss in hours'=RPO
- 'maximum downtime'=RTO

**Cenário clássico de exame:** 'backup a cada 4h'=RPO de 4h: aceitarás perder até 4h de dado.

## 🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 3.4)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer (Recovery Testing) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Modelos de Responsabilidade Compartilhada na Nuvem:**
  - **IaaS (Infrastructure as a Service):** provedor cuida da infraestrutura física/hipervisor; cliente cuida de SO, patches, middleware, rede e dados.
  - **PaaS (Platform as a Service):** provedor cuida do hardware, SO e runtime; cliente cuida do código da aplicação e dos dados.
  - **SaaS (Software as a Service):** provedor gerencia tudo; cliente é responsável apenas pelas configurações de acesso e segurança dos próprios dados.
- **Segmentação de Rede e Segurança Perimetral:**
  - **DMZ (Demilitarized Zone):** sub-rede perimetral intermediária para servidores públicos (web, mail), isolada da rede corporativa interna por firewalls.
  - **VLANs (Virtual LANs):** isolamento lógico de tráfego na camada 2 para separar departamentos sensíveis (ex: finanças, RH, visitantes).
  - **SASE (Secure Access Service Edge):** convergência de SD-WAN e serviços de segurança em nuvem (CASB, FWaaS, ZTNA) entregues próximos ao usuário.
- **Resiliência e Tolerância a Falhas de Armazenamento:**
  - **RAID 0:** striping sem tolerância a falhas (foco exclusivo em velocidade; perda de 1 disco destrói tudo).
  - **RAID 1:** espelhamento (tolera perda de 1 disco; consome 50% do espaço total).
  - **RAID 5:** paridade distribuída (mínimo 3 discos; tolera falha de 1 disco).
  - **RAID 6:** dupla paridade (mínimo 4 discos; tolera falha simultânea de até 2 discos).
  - **RAID 10 (1+0):** combinação de espelhamento e striping (alta performance e redundância).

### ⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- RAID NÃO substitui Backup. Se um arquivo for corrompido, excluído ou criptografado por ransomware, o RAID replica o dado corrompido instantaneamente nos discos espelhados.
- Na nuvem pública, a responsabilidade sobre a classificação e sigilo dos DADOS é SEMPRE do cliente em qualquer modelo (IaaS, PaaS ou SaaS).

## ✓ Perguntas de treino comentadas (10 questões)

---

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

**1. Se um servidor falha e precisa estar operacional em 4 horas conforme SLA, isso define:**

- A)** RPO (Recovery Point Objective)
- B)** RTO (Recovery Time Objective)
- C)** MTTR (Mean Time To Repair)
- D)** MTBF (Mean Time Between Failures)

**2. RTO (Recovery Time Objective) mede:**

- A)** Quanto DADO você aceita perder
- B)** Quanto TEMPO o serviço pode ficar fora
- C)** O custo do incidente
- D)** O número de usuários afetados

**3. Qual métrica define o tempo máximo aceitável de perda de dados em um plano de Disaster Recovery, medindo o intervalo entre os backups ou réplicas?**

- A)** RTO (Recovery Time Objective)
- B)** RPO (Recovery Point Objective)
- C)** MTTR (Mean Time to Repair)
- D)** SLI (Service Level Indicator)

**4. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'RPO: quantos dados podes perder; RTO: quando volta'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RPO: quantos dados podes perder; RTO: quando volta...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**5. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Plano NÃO-testado = plano que NÃO funcionará'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Plano NÃO-testado = plano que NÃO funcionará...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**6. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'maximum data loss in hours'=RPO'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'maximum data loss in hours'=RPO...

**7. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'maximum downtime'=RTO'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'maximum downtime'=RTO...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'backup a cada 4h'=RPO de 4h: aceitarás perder até 4h de dado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'backup a cada 4h'=RPO de 4h: aceitarás perder até 4h de dado....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'RPO: quantos dados podes perder; RTO: quando volta'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RPO: quantos dados podes perder; RTO: quando volta...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10. Cenário corporativo (Recovery Testing):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.4), um analista avalia o seguinte requisito técnico: 'Plano NÃO-testado = plano que NÃO funcionará'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Plano NÃO-testado = plano que NÃO funcionará...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

### 1) B — RTO (Recovery Time Objective).

✓ **Por que está certa:** RTO é o tempo máximo aceitável para restaurar um serviço/sistema após falha. RPO define a quantidade máxima de dados que podem ser perdidos (no tempo).

#### ✗ **Por que as outras estão erradas:**

- *RPO (Recovery Point Objective):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *MTTR (Mean Time To Repair):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *MTBF (Mean Time Between Failures):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 2) B — Quanto TEMPO o serviço pode ficar fora.

✓ **Por que está certa:** RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder).

#### ✗ **Por que as outras estão erradas:**

- *Quanto DADO você aceita perder:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *O custo do incidente:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *O número de usuários afetados:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 3) B — RPO (Recovery Point Objective).

✓ **Por que está certa:** RPO mede a tolerância a perda de dados (ex: RPO de 4h significa que até 4h de dados podem ser perdidos); RTO mede o tempo de restauração.

#### ✗ **Por que as outras estão erradas:**

- *RTO (Recovery Time Objective):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *MTTR (Mean Time to Repair):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *SLI (Service Level Indicator):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 4) B — Implementar a solução correspondente: RPO: quantos dados podes perder; RTO: quando volta....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Recovery Testing): RPO: quantos dados podes perder; RTO: quando volta.

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**5) A — Implementar a solução correspondente: Plano NÃO-testado = plano que NÃO funcionará....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Recovery Testing): Plano NÃO-testado = plano que NÃO funcionará.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**6) D — Implementar a solução correspondente: 'maximum data loss in hours'=RPO....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Recovery Testing): 'maximum data loss in hours'=RPO.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) A — Implementar a solução correspondente: 'maximum downtime'=RTO....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Recovery Testing): 'maximum downtime'=RTO.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) A — Implementar a solução correspondente: 'backup a cada 4h'=RPO de 4h: aceitarás perder até 4h de dado.....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 3.4 (Recovery Testing): 'backup a cada 4h'=RPO de 4h: aceitarás perder até 4h de dado..

**✗ Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) B — Implementar a solução correspondente: RPO: quantos dados podes perder; RTO: quando volta....**

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Recovery Testing): RPO: quantos dados podes perder; RTO: quando volta.

**✗ Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) B — Implementar a solução correspondente: Plano NÃO-testado = plano que NÃO funcionará....**

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.4 (Recovery Testing): Plano NÃO-testado = plano que NÃO funcionará.

**✗ Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

